Incident Response Procedure

Example Manufacturing GmbH. Document IS-07, version 2.1, owner: Chief Information Security Officer (CISO), effective 1 June 2026.

1. Purpose

This procedure describes how security incidents are reported, classified and handled, so that damage is limited and operations are restored quickly.

2. What to Report

Employees report suspected phishing, malware, unauthorised access, unusual system behaviour and lost or stolen devices to the security hotline (extension 4444) or the security mailbox. A lost or stolen laptop or phone must be reported within 1 hour of noticing the loss.

3. Severity Levels and Response Times

P1 Critical: production is stopped, ransomware is active, or a breach of sensitive data is confirmed. P1 incidents are acknowledged within 15 minutes, around the clock. An incident manager is assigned and the CISO and management are informed within 1 hour.

P2 High: a single critical system is affected or a data breach is suspected. Response within 1 hour during business hours.

P3 Medium: limited impact, for example malware on a single computer that has been contained. Response within 4 business hours.

P4 Low: policy violations or phishing emails that nobody clicked. Response on the next business day.

4. First Steps for Employees

If you suspect ransomware on your computer, disconnect it from the network by unplugging the cable and switching off Wi-Fi. Do not switch the computer off, because this can destroy evidence, and do not try to fix the problem yourself. Call the security hotline.

Report suspicious emails with the Report Phishing button and do not click any links. If you already clicked a link or entered your password, report it immediately and change your password.

5. Containment and Eradication

The security team isolates affected computers through the EDR system, preserves evidence (where possible a memory image before any restart), resets compromised credentials and removes the cause of the incident before systems are restored from clean backups.

6. Communication and Reporting Obligations

Only the Communications department speaks to the media. Customers are informed by account management after approval by Legal.

Where the company is subject to the NIS2 directive, significant incidents are reported to the BSI: an early warning within 24 hours of becoming aware of the incident, an incident notification within

72 hours, and a final report within one month. Personal data breaches follow the Data Protection and Retention Policy (DP-02).

7. Post-Incident Review

A post-incident review is held within 5 working days after a P1 or P2 incident is closed. Lessons learned and follow-up actions are tracked in the risk register.

8. Exercises

The incident response team runs a tabletop exercise twice a year. At least one exercise per year uses a ransomware scenario.